

-

File No.: EXP202210727

RESOLUTION OF ARCHIVE OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: On August 30 and September 24, 2022, two complaints were filed with the Spanish Agency for Data Protection against BANCO BILBAO VIZCAYA ARGENTARIA, S.A. (hereinafter, the complained party).

The reasons for the complaint are as follows:

The complainant states that, on September 6, 2021, a third party fraudulently modified the address data related to the account owned by their mother (in which the complainant was listed as authorized), as well as the request for a second card associated with said account (which was not requested by the complainant or by their mother) and the subsequent fraudulent use of said card at ATMs.

On October 5, 2021, the complainant informed the complained party of the facts, repeatedly requesting to know the manner and identity of the third party who modified the address data associated with the bank account, as well as the identity of the requester of the second card, without success, since on May 18 and January 21, 2022, the complained party stated that the disputed address was provided by the complainant when registering the contract related to the card, on September 6, 2021, as stated in the document titled "Data Protection Policy and Economic Activity Declaration," all "with the correct insertion of their personal keys," adding that "a communication was sent to their validated email in which the pre-contractual information and the card contract were attached for review prior to signing and an SMS to their validated mobile phone, informing of the card PIN (...). In the case presented to us and following the criteria of good practices required of entities, at BBVA we have acted fully in accordance with these criteria."

Furthermore, regarding the unrecognized charges made with the disputed card, a response was received on February 28, 2022, indicating that "on a punctual basis" they had proceeded to attend to the complainant's request favorably, requesting that a bank account number be provided for the reimbursement.

On the other hand, it is stated that the complainant's mother, on May 24, 2022, requested from the complained party (through the address derechosprotecciondatos@bbva.com) to know "the date on which she requested and the day she canceled" the disputed card, receiving a response (on June 3 and 28, 2022) indicating the following: "We regret to inform you that we have been unable to process your request, as the subject of it is excluded from the exercise of rights provided by the LOPD," indicating other channels to which to direct inquiries, among which was the Customer Service, with a response from that department dated July 29, 2022, indicating that "regarding the contract of the indicated card, we regret to inform you that, despite the efforts made, it has not been possible to locate said documentation."

Along with the complaint, the following is submitted:

- Power of attorney dated August 29, 2022.

Regarding the fraudulent use of the credit card and account charges

- First page of the document "Personal Data Protection Policy and Economic Activity Declaration" in which the changed address and the phone number for SMS messaging and contact email address that correspond to the complainant are noted (document 1).

- Communication to the entity via mobile banking requesting an appointment due to the change of address by unknown persons and the fraudulent use of the bank card dated October 4, 2021 (document 5).

- Communication to the complainant sent by the complained party dated January 26, 2022, informing the former that the documentation had been forwarded to the fraud department (document 6).

- Response dated February 28, 2022, from the Customer Service department sent to the complainant informing them that it had been decided to resolve their case favorably (document 10).

- Communication dated August 17, 2022, sent to the complainant informing them that the requested

compensation had been approved (document 25).

Regarding the right of access and authorship of the address change and contracting of the card in controversy

- Requests addressed to the entity, dated December 16, 2021, and January 3, 2022, for them to provide all notifications and communications sent through the mobile app during the year 2021, a copy of all SMS messages sent, and a copy of all email messages sent, to the phone and email address reported to the entity (documents 2 and 3).

- Information requests, dated January 19, February 9, March 24, April 20, and August 16, 2022, regarding the author, the moment, and the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/11

Procedure for obtaining the fraudulent credit card (documents 4, 7, 12, 14, 16, and 24).

-

Communication, dated January 21, 2022, sent by the respondent to the claimant informing them that the change of address and contracting of the disputed card was carried out on September 6, 2021, through online banking with the correct entry of their personal keys, and that a communication was also sent to their validated email address in the entity, which included the pre-contractual information and the contract for the card, for their review before signing, and an SMS to their validated mobile phone, informing them of the card's PIN (document 11).

-

Exercise of the right of access to their personal data dated March 24, 2022 (document 12).

-

Written communication dated April 20, 2022, informing the claimant that their data is blocked in accordance with the provisions of Article 15 of the Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights (hereinafter, LOPDGDD) and Article 17 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 (General Data Protection Regulation, hereinafter, GDPR), due to not currently maintaining a contractual relationship with BBVA. However, solely for the purpose of addressing their request, they provide the data that was subject to processing and all aspects established in Article 15 of the GDPR (document 15). Among the contracted products is, in addition to the disputed card, an AQUA CREDITO card, with contract number ***CONTRATO.1, which the claimant does not recognize and for which they request, dated July 13, 2022, the contract for this (document 21).

-

Response from Customer Service, dated July 29, 2022, regarding the claimant's request about the date of application and cancellation of the AQUA CREDITO bank card with contract number ***CONTRATO.1, stating "regarding the contract of the indicated card, we regret to inform you that, despite the efforts made, it has not been possible to locate said documentation" (document 22).

SECOND: In accordance with Article 65.4 of the Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights (hereinafter LOPDGDD), this complaint was forwarded to the respondent, so that they could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/11

The transfer, which was carried out in accordance with the regulations established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on October 14, 2022, as stated in the certificate included in the file.

On November 22, 2022, this Agency received a response letter, in which they state that the request for

a change of address was made by the claimant on September 6, 2021, and that the contracting of the new card was carried out through the digital signature of the contract. They include an excerpt from the certificate of the qualified digital certification entity CAMERFIRMA, in which the digital signature of the contract for the card under the request of the claimant can be seen. They also include in this letter a screenshot of the records related to the claimant from September 2021 available in their systems, which shows the email sent on September 6, 2021, of the contract to be digitally signed by the claimant to their email address, and the SMS sent to the claimant's phone with the PIN of the contracted card, and on September 8, the sending of the card to the address.

Regarding the different requests for information sent by the claimant to the responding entity concerning the change of address and the contracting of the disputed card, the responding entity states that all were addressed.

About the AQUA CREDITO card, which does not correspond to the card used for the disputed transactions, they state that they informed the claimant on July 29, 2022, that it had not been possible to locate the documentation related to this card and provide information on the contracts listed in their database of bank cards in the name of the claimant.

They conclude by indicating that the claimant themselves reported in an email dated January 26, 2022, sent to their entity, that "on September 6, 2021, around noon, I had difficulties opening the BBVA app on my phone and had to enter the codes sent by SMS several times in that app. Once inside the app, a small window asked for the name and address of the account holder. And finally, it opened." They include in this letter a screenshot of the aforementioned email.

And they attach the following relevant documentation not provided by the claimant:

- Letter dated November 22, 2022, addressed to the claimant summarizing all the actions taken at their request and the responses sent (document 1)
- Letter dated October 27, 2022, addressed to the claimant informing them of the transfer of this Agency of their claim and providing some security recommendations to avoid banking fraud (document 14).

THIRD: On November 30, 2022, in accordance with Article 65 of the LOPDGDD, the claim submitted was admitted for processing.

FOURTH: The General Subdirector of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/11

Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

Regarding the possible identity theft

Requested from the respondent by the security protocols and procedures for the modification of personal data including the validation data for operations and card contracting and detailed documentation of the identity accreditation of the acting party in the change of address of the complainant and request for a bank card in dispute NOW with contract number ***CONTRACT.2: validation of keys, two-factor signature method accrediting data of the sending, validation signature, additional measures if any had existed, etc. for the indicated operations, on the dates of May 3 and 24, 2023, a written statement of allegations and attachments is received in this Agency. In the written statement of allegations, there is a screenshot of the history of the keys sent to the validated phone number of the complainant (OTP-SMS) to validate each of the operations: change of address, request for a card, and change of the availability limit at ATMs of the card, which was initially 1,000 euros.

In attached document 1, regarding the analysis of evidence of the disputed operations, a screenshot of the existing traces in their systems is presented, confirming that the change of address was made on September 6, 2021, at 13:42:01h and the request for a card a few minutes later at 13:47:00h, and the

change of the card limit at 13:48:18, with all requests made from the IP ***IP.1 associated with the provider ORANGE ESPAGNE S.A.U., and through authentication on the BBVA NET platform using the personal username and password of the complainant.

Additionally, in explanatory document EXP202210727_resto_documentos.pdf, received in this Agency on March 24, 2023, the digital signatures made from the phone number of the complainant are certified by the entity CAMERFIRMA for all the disputed operations: change of address, signing of the card contract, and limit increase.

From the above, it follows that the person who carried out these operations must have known the remote banking credentials of the complainant in addition to having access to the SMS text messages from their phone number and possibly to the email inbox.

Regarding the execution of the digital signatures of the operations through keys sent by SMS, this could only have been possible by having access to the complainant's phone number, either because prior to the signature a SIM card swap had been requested from the operator of that number, or because a duplicate SIM or eSIM for that number had been requested from the operator, or because the complainant's device had been compromised and SMS forwarding had been programmed. The first option has been ruled out because it would imply the loss of the line by the complainant, and in none of their writings has this fact been stated.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/11

In accordance with the above, the operator of this mobile number is required to inform whether a duplicate SIM or eSIM of the claimant's mobile phone number was requested between January 1, 2021, and September 30, 2021, and, if applicable, provide a detailed description of the procedure used, identification of the requester, and a copy of the documentation required to verify identity. In response to this request, on June 7, 2023, a letter was received by this Agency from this entity stating that after consulting with the Analysis and Risk Group, they concluded that there are no records of SIM duplicates, call forwarding, or multiSIM in their internal systems. In this regard, they determined that there are no indications of irregular activations or illegitimate actions.

In order to determine whether the claimant's mobile device had been recently manipulated by third parties, the last possibility that third parties could have access to SMS messages, the claimant was requested to inform this Agency whether the mobile device was lost and recovered, or taken for maintenance to any business prior to the events that occurred in September 2021. Additionally, a copy of the police report filed with reference number ***REFERENCIA.1 was also requested in case there was any additional information that could clarify the facts. Although the notification was collected by the claimant on May 25, 2023, as of the date of this report, no response has been received.

It has therefore not been possible to determine how and who could have accessed the claimant's phone number to carry out the signatures of the disputed operations.

Regarding the exercise of the right of access by the claimant

With respect to the multiple requests directed to the respondent, the first of which was on January 19, 2022, according to the documentation submitted, regarding the origin, how, and when the change of address occurred, the respondent sent a response to the claimant on January 21, 2022, as stated in the documentation provided by the claimant (document 11).

Regarding the right of access to their personal data exercised by the claimant on March 24, 2022, the respondent replied on April 20, 2022, informing the claimant of the data that was subject to processing and all aspects established in Article 15 of the GDPR (document 15), indicating that their data was blocked due to the lack of a contractual relationship with the respondent and that the processing was carried out solely for the purpose of addressing their request.

Regarding the security measures required for identity verification

As previously mentioned, the records of the respondent entity indicate that the operations were carried out through authentication with personal keys and signatures certified by the qualified certification entity CAMERFIRMA. Furthermore, both the contract and the OTP-SMS were sent to the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/11

validated media in the claimed entity and that has been verified to correspond to the claiming party. Regarding the AQUA CREDITO card with contract number ***CONTRATO.1 that the claiming party does not recognize, and for which the claimed party states it cannot find the documentation related to that card, in October 2020 the banking entity launched a campaign regarding the first card with dynamic verification code and hidden card numbering with the aim of mitigating potential fraud, taking a further step than what is established in the European Directive regulating payment services (PSD2). According to the claimant's own statement in an email sent to the claiming party on August 16, 2022 (document 24), the entity offered him in June 2021 the change of his AHORA card for the AQUA card due to increased security. In this regard, although the entity cannot find the documentation regarding this card, this card is listed in the document that grants access to his personal data (document 15). Regarding the diligence of the claimed party concerning the amounts withdrawn and their restitution Regarding the management by the claimed entity in the reimbursement of amounts withdrawn from ATMs fraudulently and their restitution, it should be noted that the activity of the AEPD concerning complaints is not aimed at the interpretation and assessment of the diligence required in the fulfillment of such obligations arising from a possible fraud situation. However, upon examining the submitted documentation, it is concluded that the claiming party received from the claimed entity the reimbursements corresponding to the amounts withdrawn from ATMs fraudulently, in addition to the amount requested as compensation.

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f) and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative proceedings.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/11

II

Legality of processing

Article 6 of the GDPR, which regulates the legality of processing, establishes the following:

"1. Processing shall be lawful only if at least one of the following conditions is met:

- a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary in order to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the

exercise of official authority vested in the controller;

f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child.

The provision in point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks.

2. Member States may maintain or introduce more specific provisions to adapt the application of the rules of this Regulation with respect to processing under paragraph 1, points c) and e), laying down more precise requirements for specific processing and other measures to ensure lawful and fair processing, including other specific situations of processing under Chapter IX.

3. The basis for processing referred to in paragraph 1, points c) and e), shall be laid down by:

a) Union law, or

b) the law of the Member States applicable to the controller.

The purpose of the processing shall be determined in that legal basis or, in relation to the processing referred to in paragraph 1, point e), shall be necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller. This legal basis may contain specific provisions to adapt the application of the rules of this Regulation, among others: the general conditions governing the lawfulness of processing by the controller; the types of data subject to processing; the data subjects

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/11

Affected; the entities to which personal data may be communicated and the purposes of such communication; the limitation of purpose; the retention periods of the data, as well as the operations and procedures of processing, including measures to ensure lawful and fair processing, such as those related to other specific processing situations under Chapter IX. The law of the Union or of the Member States shall pursue a public interest objective and shall be proportionate to the legitimate aim pursued.

4. When the processing for a purpose other than that for which the personal data were collected is not based on the consent of the data subject or on Union or Member State law that constitutes a necessary and proportionate measure in a democratic society to safeguard the objectives set out in Article 23(1), the data controller, in order to determine whether the processing for another purpose is compatible with the purpose for which the personal data were initially collected, shall take into account, among other things:

a) any relationship between the purposes for which the personal data were collected and the purposes of the intended further processing;

b) the context in which the personal data were collected, in particular with regard to the relationship between the data subjects and the data controller;

c) the nature of the personal data, in particular when special categories of personal data are processed, in accordance with Article 9, or personal data relating to criminal convictions and offenses, in accordance with Article 10;

d) the possible consequences for the data subjects of the intended further processing;

e) the existence of appropriate safeguards, which may include encryption or pseudonymization."

III

Security of Processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, where appropriate, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/11

as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements established in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data can only process such data following the instructions of the controller, unless required to do so by Union law or the law of the Member States.

IV

Conclusion

It should be noted that there is no documentation provided by the claimant that includes the email sent to the defendant entity, dated January 26, 2022, stating that on September 6, 2021, at noon, they had difficulties opening the BBVA app on their mobile phone and had to enter the codes sent via SMS multiple times in that app, and that once inside the app, a window opened asking for the name and address of the account holder in order for it to finally open.

This information is of utmost interest as in this case the claimant could have been a victim of some type of app or website forgery by the defendant, or the installation of malicious software on their mobile device.

In fact, as previously mentioned, in the communication dated January 21, 2022, sent by the defendant to the claimant, it informed the latter that the change of address and the contracting of the disputed card that took place on September 6, 2021, through online banking, was done with the correct entry of their personal codes and that a communication was also sent to their validated email address at the entity, which included the pre-contractual information and the contract for the card, for their review before signing, and an SMS to their validated mobile phone, informing them of the card's PIN (document 11).

Everything points to the fact that the claimant was a victim of impersonation of the mobile application or website, or of the installation of malicious software, with which a third party obtained their codes and accessed the SMS messages sent to the claimant in such a way that they could change their address, request the disputed bank card, and increase the withdrawal limit at ATMs. In this regard, it is verified that the defendant took reasonable security measures by obtaining the digital signature for each of the disputed operations from the validated phone number of the claimant and through the qualified certification entity CAMERFIRMA.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The amounts withdrawn unlawfully were refunded by the defendant entity in addition to the payment of the compensation requested by the claimant.

Regarding the exercise of access to their data, this was responded to in a timely manner, providing the data subject to that right in accordance with Article 15 of the GDPR (regarding the contracted products and declarations of economic activities).

Therefore, based on the information provided in the previous paragraphs, no evidence has been found to substantiate the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

In accordance with the above, the Director of the Spanish Agency for Data Protection, IT IS AGREED: FIRST: TO PROCEED TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to BANCO BILBAO VIZCAYA ARGENTARIA, S.A., and to the claimant.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-020323

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es